

TRAINING @ FORREST ONE

Session 10 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Vulnerability Management, Resiliency & Asset Protection

Harden from a known good state, secure the edge, then run the vulnerability loop.

BASELINES

HARDENING

MOBILE

VULNERABILITY



WELCOME · THE SESSION AHEAD

Six chapters, from a secure baseline to a tuned alert

- **1 · Baselines and hardening** the known good state you build from, and hold
- **2 · Mobile and wireless** the devices that leave, and the air inside
- **3 · Applications and monitoring** harden the software, then watch what it touches
- **4 · The asset lifecycle** acquisition, assignment, tracking and disposal
- **5 · Vulnerability management** identify, analyse, prioritise, remediate, report
- **6 · Monitoring tooling** collect, correlate, tune, and act in time

The thread through all six

You cannot protect what you have not hardened, and you cannot fix what you cannot find. A finding nobody prioritised is a decision made by default.



SESSION OBJECTIVES

By the end of this session you will be able to

- **Implement a baseline** and detect configuration drift
- **Harden three layers** operating system, application and firmware
- **Secure mobile and wireless** central control, current encryption
- **Defend the application** validation, allow listing, sandboxing, signing
- **Monitor the estate** authentication, privilege, traffic, change
- **Manage the asset lifecycle** acquire, assign, track, sanitise, dispose
- **Run the vulnerability loop** scan, score, prioritise, remediate, report
- **Tune the tooling** SIEM, behaviour analytics, dashboards, alerts



CHAPTER 1 OF 6 · BASELINES AND HARDENING

Building from a known good state

- **Secure baseline** the documented minimum configuration a system must have before deployment
- **Configuration drift** the divergence that arrives through unauthorised changes and missed updates
- **Why it matters** compliance becomes a comparison against a written standard, not an argument
- **This chapter** baselines, the tools that enforce them, and hardening at three layers

The premise

Every system should start from a known secure state. Start secure, then prove you stayed secure.



TOPIC 10A · BASELINES

A known secure state

- **Secure baseline** the documented set of minimum security settings a system needs before deployment
- **Configuration drift** two machines that should be identical, quietly diverging
- **Compliance made verifiable** an auditor compares the machine against the standard
- **Two identical machines** without a baseline they drift, and normal is undefined
- **The rule** start secure, then prove you stayed secure



TOPIC 10A · BASELINES

Implementing a baseline

- **1 · Identify the requirements** regulation, industry standards and your own policy
- **2 · Develop the configuration** operating system, application and network settings
- **3 · Test and validate** in a controlled environment before live use
- **4 · Deploy, then monitor** deploy before production, then watch for drift

Sources

Centre for Internet Security Benchmarks and vendor hardening guides give you a defensible starting configuration.



TOPIC 10A · BASELINES

Configuration management tools

Tool	What it does	How it is defined
Ansible	Automates provisioning, configuration and deployment	Human readable YAML files
Puppet	Manages infrastructure across its lifecycle	Declarative language
Chef	Automates deployment and ongoing management	Domain specific language on Ruby
SaltStack	Fast and scalable for large estates	Master and minion architecture

Why automate

Automation applies the approved settings, watches for drift and reports the system that left the standard. It is the only realistic way to hold thousands of systems to one baseline.



TOPIC 10B · HARDENING

System hardening: shrink the attack surface

- **Attack surface** every point where an attacker can send or take data
- **Audit services** disable what the system does not need
- **Close unused ports** many systems enable a wide range by default
- **Default accounts** remove them, or give a unique password and minimal rights
- **Least privilege** a practice, not a setting
- **The payoff** less to patch, less to monitor, less to explain



TOPIC 10B · HARDENING

Three layers: operating system, application, firmware

Layer	What hardening means	The exam point
Operating system	Patch, disable services, mandatory access control	Confines each program to what it should touch
Application	Secure configuration, updates, input validation	Input validation belongs in the build
Firmware	Current versions, and secure boot enabled	Secure boot refuses unauthorised firmware

Why all three

Skip one layer and the others still carry risk, because an attacker takes the easiest path available.



TOPIC 10B · HARDENING

Balancing security and functionality

- **The risk of over-hardening** a control that blocks a process gets switched off quietly
- **Assess the impact** before you apply the change, not after
- **Test somewhere safe** a controlled environment, never production first
- **Document and review** record the change, then revisit it against operational need
- **The goal** the most secure machine the business can actually run

Analyst's lens

Documented and tested hardening survives. Heroic hardening is rolled back, usually without telling the security team.



CHAPTER 2 OF 6 · MOBILE AND WIRELESS

Mobile devices and wireless

- **The problem** devices leave your control every day and join networks you do not own
- **The airwaves** wireless is a shared medium that spills past your walls
- **The response** secure the device, the data on it, and the air it speaks over
- **This chapter** mobile risk, ownership models, wireless encryption and authentication

The mindset

Treat a phone like the server it has become, because it holds more of your data than one.



TOPIC 10C · MOBILE

Mobile devices: the unique risks

- **Portability** loss and theft are likely, not hypothetical
- **Many platforms** different operating systems, different security models
- **App ecosystem** third party applications arrive unvetted
- **Connectivity** public Wi-Fi invites interception
- **Mobile device management** policy, configuration, compliance checks, remote wipe
- **The rule** the device you cannot reach is the device you cannot defend



TOPIC 10C · MOBILE

BYOD or corporate owned?

Strategy	What you gain	What you give up
BYOD	Flexibility, lower hardware cost	Less control over the device
Corporate owned	Strict configuration and compliance	Higher cost, less user freedom
Containerisation	Work data isolated from personal data	Depends on MDM and clear policy
Application vetting	Only assessed apps reach corporate data	Slower, less user choice

What vetting asks

Weak storage, poor encryption, policy compliance and developer reputation decide whether an app may touch corporate data.



TOPIC 10D · WIRELESS

Wireless encryption: four generations

Standard	Cipher and handshake	Status
WEP	RC4 with a weak integrity check	Broken and obsolete
WPA	Temporal Key Integrity Protocol: a key per packet	Still RC4, superseded
WPA2	Advanced Encryption Standard, pre-shared key or enterprise	The current baseline
WPA3	Simultaneous Authentication of Equals handshake	Resists offline guessing

Each generation exists because the last one failed

WPA3 also adds forward secrecy, so a stolen key cannot unlock past sessions.



TOPIC 10D · WIRELESS

Authentication and rogue access points

- **Pre-shared key** one passphrase for everyone: simple at home, weak at scale
- **Enterprise** each credential checked by a RADIUS server
- **Why enterprise wins** one user can be removed without changing everybody
- **Rogue access point** unauthorised hardware on your premises
- **Detection** wireless scanning and prevention on the spectrum
- **Site survey** coverage that stops at your walls, plus security zones



BREAK
10 MINUTES

Back soon: applications, assets, and the vulnerability loop.



Applications and monitoring

- **Why applications** they face users, they accept input, and most attacks land there
- **Two moves** harden how software is built, then watch what it touches
- **The defences** a firewall in front, sandboxing inside, allow listing on the host
- **This chapter** secure coding, application defences, and monitoring fundamentals

The framing

An application that accepts input is talking to a stranger. Validate what it says back.



TOPIC 10E · APPLICATIONS

Secure coding and input validation

- **Least privilege** run code with the minimum rights it needs
- **Error handling** never leak internal detail in a message
- **Code review** find flaws before release, not after
- **Input validation** allow known good data, sanitise the rest
- **Boundary checking** enforce length and format limits
- **The payoff** most injection attacks die at a well written input check

Allow list, not block list

List the good rather than trying to enumerate every bad, because the bad list is never finished.



TOPIC 10E · APPLICATIONS

Application defences

Defence	What it does	Where it earns its place
Web application firewall	Filters and monitors web traffic	Internet facing applications
Sandboxing	Runs code isolated with limited access	Untrusted content and testing
Allow listing	Only pre-approved applications may run	Servers and fixed function endpoints
Code signing	Signature proves origin and integrity	Software distribution
Runtime self-protection	Watches behaviour live and blocks the attack	Production applications



DISCUSSION

Assume something malicious will arrive. What stops it running, what contains it, and what proves it is genuine?

An allow list decides what may run, a sandbox limits what running code may touch, code signing verifies the binary, and monitoring catches what slips past all three.

Layer them and you cover prevent, contain, verify and detect, in that order of intent.



TOPIC 10F · MONITORING

Security monitoring: what to watch

- **What monitoring is** continuous observation, to spot an event in time to act
- **Authentication attempts** a burst of failures is a credential attack in progress
- **Privilege usage** administrator accounts are the prize, especially at odd hours
- **Network traffic** a sudden outbound spike suggests exfiltration
- **System changes** new services, modified configuration, altered critical files
- **The rule** you cannot spot abnormal until you know normal



TOPIC 10F · MONITORING

Alerting strategy and monitoring scope

- **Real-time alerting** catch the active threat now
- **Trend analysis** read the history to see the campaign
- **Scope** more sources give a fuller picture, and far more data
- **Storage** a wider scope needs capacity and a retention policy
- **Detection** more data needs better filtering to stay useful
- **Alert fatigue** too many alerts hide the one that mattered

The trade off

Scope sets both your storage bill and your detection ceiling, so choose it deliberately.



CHAPTER 4 OF 6 · THE ASSET LIFECYCLE

The asset lifecycle

- **The premise** you cannot protect what you do not know you own
- **The journey** specify, acquire, assign, track, and destroy at end of life
- **The unglamorous work** inventory, ownership, custody, licensing, disposal
- **Why it matters** these decide whether an incident stays small

The line to remember

You cannot patch what you cannot find, and the first question after a compromise is what else touched it.



TOPIC 10G · ACQUISITION

Asset acquisition

- **Start at the purchase order** write the security requirements into procurement
- **Assess the vendor** reputation, compliance record and security practice
- **Verify the supply chain** audits, and traceability of every component
- **What this defends** a malicious change during manufacture or delivery
- **The rule** an asset chosen carelessly is risk you never scanned for



TOPIC 10G · ASSIGNMENT

Assignment: owner and custodian

- **Owner** accountable for the asset, and decides how it may be used
- **Custodian** updates, access control, and keeping the record current
- **Inventory** what exists, where it is, who holds it
- **Classification** how sensitive it is, and how damaging to lose
- **Why accuracy matters** the first question after a compromise is what else touched it



TOPIC 10H · TRACKING

Tracking location, configuration and patch state

- **Location** track the laptops and phones that move, so you can find and wipe them
- **Configuration** hardware, software, network settings and permissions
- **Patch state** current, pending, or deliberately refused
- **Licences** know how many you own and how many are installed
- **Unauthorised installs** find them by audit and allow listing

Why it counts twice

An unapproved application is a licensing risk and a security one at the same time.



TOPIC 10H · DISPOSAL

Secure disposal and data sanitisation

Method	What it does	Best for
Overwriting	Replaces the data with random data	Media returning to service
Degaussing	A strong magnetic field erases magnetic media	Disks, and no good for flash
Physical destruction	Shredding or crushing the device	End of life hardware
Verification	Confirms nothing can be recovered	Every disposal, without exception

The rule

A destruction process nobody checked is a hope rather than a control. Document the method and the people involved.



TOPIC 10H · DISPOSAL

Chain of custody and compliance

- **Chain of custody** a unique identifier, every transfer, and the disposal record
- **Record the detail** dates, times and personnel at every handover
- **Regulation** personal and health data duties under the GDPR and HIPAA
- **Audit the process** and close the gaps the audit finds
- **The evidence** documentation is how you prove compliance

The overlooked control

A discarded drive is a data breach waiting to be discovered, and the paperwork is what protects you.



CHAPTER 5 OF 6 · VULNERABILITY MANAGEMENT

Vulnerability management

- **The loop** identify, analyse, prioritise, remediate, validate, report
- **It never closes** the estate and the threat both keep changing
- **Identify** scanners and current intelligence feeds
- **Then judge** severity is a number, risk is a decision

The rule

A finding nobody prioritised is a decision made by default, and the report is how you prove the loop is running.



TOPIC 10I · IDENTIFICATION

Vulnerability identification: scanning tools

- **Network scanners** routers, switches and firewalls: open ports, old protocols, old versions
- **Host scanners** one device at a time: operating system, applications, configuration
- **Application scanners** injection, cross-site scripting and weak authentication
- **What they find** known weaknesses on the systems you know about
- **The blind spot** no scanner finds a design flaw

Remember

Scanning is necessary, and never sufficient.



TOPIC 10I · IDENTIFICATION

Scanning modes and coverage

Decision	The option	The limit
Credentialed	Sees internal state and missing patches	Needs valid credentials
Non-credentialed	Sees what an unauthenticated attacker sees	Misses everything inside
Schedule	Matches how fast your risk changes	Must not disrupt operations
Scope	Covers every critical asset	A missed database is a false comfort
Feeds	CVE identifiers keep tooling current	Only as current as the feed



TOPIC 10J · ANALYSIS

CVSS: three metric groups

- **Base** attack vector, complexity, privileges, impact on the three pillars
- **Temporal** exploit code available, fix available, report confidence
- **Environmental** how much this asset matters to your organisation
- **Why two move** the world changes, so temporal and environmental scores change
- **The exam line** a high base score with no exploit and no exposure is not an emergency

The distinction

Base scores the flaw. Temporal and environmental score your risk.



TOPIC 10J · PRIORITISATION

Beyond the score: deciding priority

Factor	The question	Why it changes priority
Asset criticality	Does it run a critical function or hold crown jewels?	Business impact sets urgency
Exposure	Is it internet facing or well connected?	Reachable flaws get attacked
Exploitability	Is working exploit code used in the wild?	Active exploitation outranks a score
False positive	Does the finding survive a manual check?	Validation protects scarce effort

The exam line

Exposure and active exploitation beat the raw score, and a score is not a decision.



QUIZ

Activity: prioritise and validate

- An internet facing service scores 7.5 (medium) with exploit code in the wild: priority?
- An isolated test server scores 9.8 (critical) with no exploit: same queue?
- A scan reports a flaw the engineer cannot reproduce: what now?
- Debrief: which factors outweigh the score?

Exposure and active exploitation outrank the number. Validate a suspected false positive before you act, because a manual check protects scarce effort.



Remediation options

- **Patch** update the software and remove the flaw, once a vendor fix exists
- **Configuration change** disable a service or tighten a default to close the door
- **Compensating control** extra monitoring, logging or detection where you cannot fix it
- **Risk acceptance** a documented decision that fixing costs more than the impact
- **The rule** every exception needs an owner, a risk statement and a date

Unpatchable is not unmanageable

It reduces the risk without removing the flaw, so it needs an owner and a review date on the record.



Validation, exceptions and reporting

- **Rescan** confirm the patch applied and nothing residual remains
- **Exceptions** document why, assess the risk, compensate, set a date, review
- **Metrics** counts by severity, average time to patch, percentage patched
- **Trends** recurring weaknesses, and whether the work is helping
- **Stakeholders** executives want impact, engineers want detail

Remember

An unreported finding is an unmanaged finding, and never let one disappear because it became inconvenient.



CHAPTER 6 OF 6 · MONITORING TOOLS

Monitoring tools and technologies

- **The purpose** turn raw events into decisions you can act on
- **The platforms** collect, correlate, store and query the evidence
- **The discipline** dashboards and thresholds that stay useful
- **The rule** a tool nobody tunes is an expensive log file

Why tooling matters

Every control we have discussed produces logs, and logs on their own change nothing.



TOPIC 10L · TOOLING

Monitoring tooling

Tool	What it does	The value
Security information and event management	Aggregates and correlates logs from many sources	Patterns no single log shows
Log management platform	Collects, stores and queries log data	Forensics and retention duties
Network traffic analysis	Captures and inspects packets	Exfiltration and denial of service
File integrity monitoring	Watches critical files against a baseline	Tampering and persistence

The point of correlation

An event that looks harmless in one log becomes obvious across three, which is why aggregation comes first.



Behaviour analytics, dashboards and alert tuning

- **User and entity behaviour analytics** learn normal per account and device, then flag the deviation
- **Risk scoring** rank investigations by strange behaviour, not by noise
- **Dashboard design** few metrics, drawn clearly, showing the trend
- **Alert tuning** adjust thresholds and rules to cut false positives
- **The cost of noise** an analyst drowning in alerts will miss the one that mattered

The closing rule

Tune your alerts, or your analysts will miss the real one when it arrives.



QUIZ

Check your understanding

- Open Quiz_Session_10.html in your browser.
- 20 questions, immediate feedback, topic tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a session topic, and each explanation teaches as much as the answer.



KEY TAKEAWAYS

- **Build from a baseline** drift is the enemy.
- **Harden three layers** fewer services, ports, accounts.
- **Secure the edge** current encryption, central control.
- **Defend the application** validate, allow list, sandbox, sign.
- **Account for assets** acquire, assign, track, sanitise, destroy.
- **Run the loop** scan, score, remediate, rescan, report.
- **Tune the tooling** or your analysts miss the real alert.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Write a baseline** pick one system and list the settings you would enforce
- **Inventory a room** count the assets, name the owner, note the patch state
- **Find one unpatchable flaw** and write its compensating control and review date
- **Read ahead** Session 11: security operations, monitoring and incident response



NEXT SESSION

Session 11 - Security Operations: Monitoring, Incident Response & Forensics

- Monitoring, alerting and log analysis
- The incident response lifecycle
- Forensics: evidence, chain of custody and timelines

Watching, responding and proving: the operational core, where the evidence from this session gets used.

